

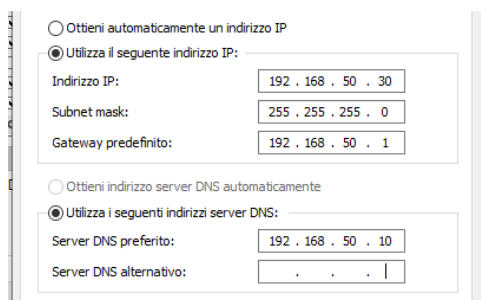
Progetto S10-L5

Report: Implementazione e Gestione dei Gruppi di Sicurezza in Windows Server 2022

“La prima regola del progetto Mayhem è: non si fanno domande.”

Preparazione dell'Ambiente e dell'Infrastruttura

L'infrastruttura di base è stata implementata su un ambiente Windows Server 2022, promosso a Domain Controller per il dominio Active Directory denominato **fightclub.local**. L'accesso al server è stato effettuato mediante account con privilegi amministrativi di dominio (Domain Admin), requisito fondamentale per la gestione centralizzata degli oggetti di directory. L'ambiente prevede inoltre la presenza di una macchina client (Client2), attestata sull'indirizzo IPv4 statico 192.168.50.30 e con i DNS puntati al Domain Controller (192.168.50.10). Il client è stato unito (joinato) con successo alla foresta del dominio per consentire i test delle utenze e delle policy.



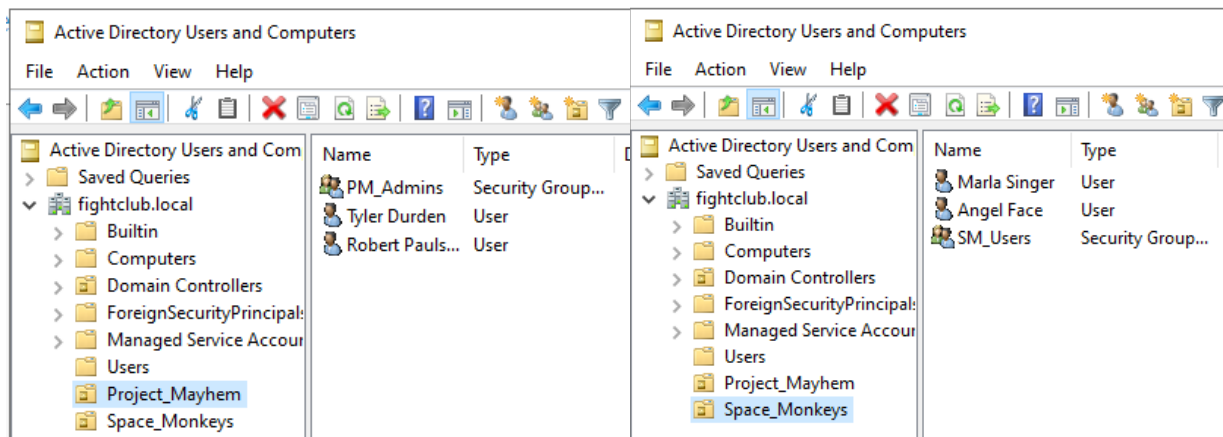
Specifiche dispositivo

Nome dispositivo	Client2
Nome completo del dispositivo	Client2.fightclub.local

Creazione della Struttura Organizzativa e dei Gruppi

Al fine di riflettere la rigida gerarchia logica e le funzioni dei vari ruoli (secondo il tema "Fight Club"), la directory è stata segmentata creando due specifiche Unità Organizzative (OU). All'interno di ciascuna OU è stato creato un Gruppo di Sicurezza con ambito Globale, popolato con utenze dedicate.

- **Unità Organizzativa "Project_Mayhem"** Rappresenta il livello direttivo e amministrativo dell'infrastruttura.
 - Gruppo: PM_Admins
 - Utenti assegnati: Tyler Durden, Robert Paulson.
- **Unità Organizzativa "Space_Monkeys"** Rappresenta il livello degli utenti standard, i quali necessitano di un accesso strettamente limitato alle sole risorse indispensabili.
 - Gruppo: SM_Users
 - Utenti assegnati: Marla Singer, Angel Face.



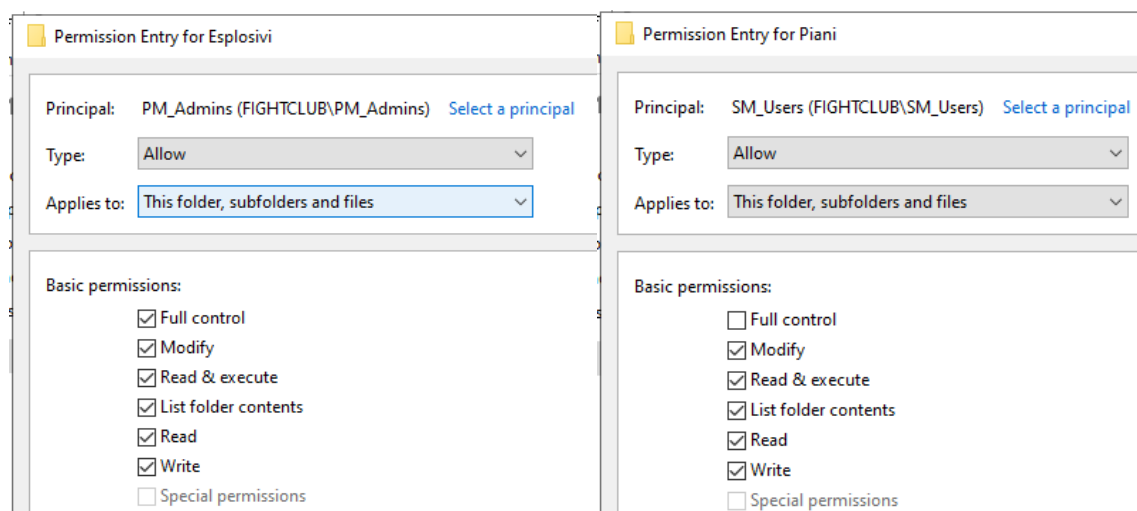
Assegnazione dei Permessi e delle Policy

L'assegnazione dei permessi è stata divisa in due macro-aree: sicurezza del File System (NTFS) e configurazione delle policy di sistema (GPO).

Gestione Accesso a File e Cartelle (Sicurezza NTFS)

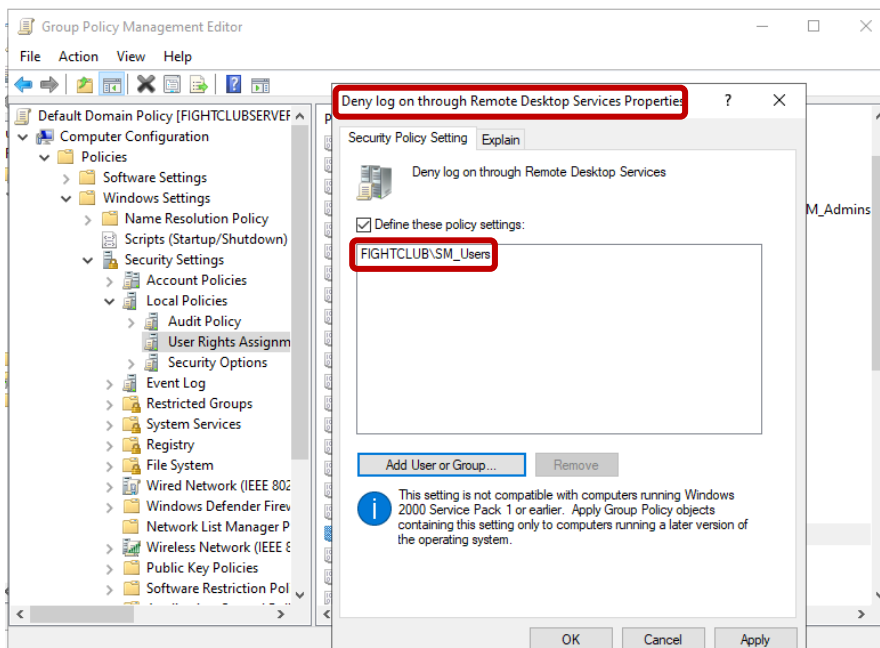
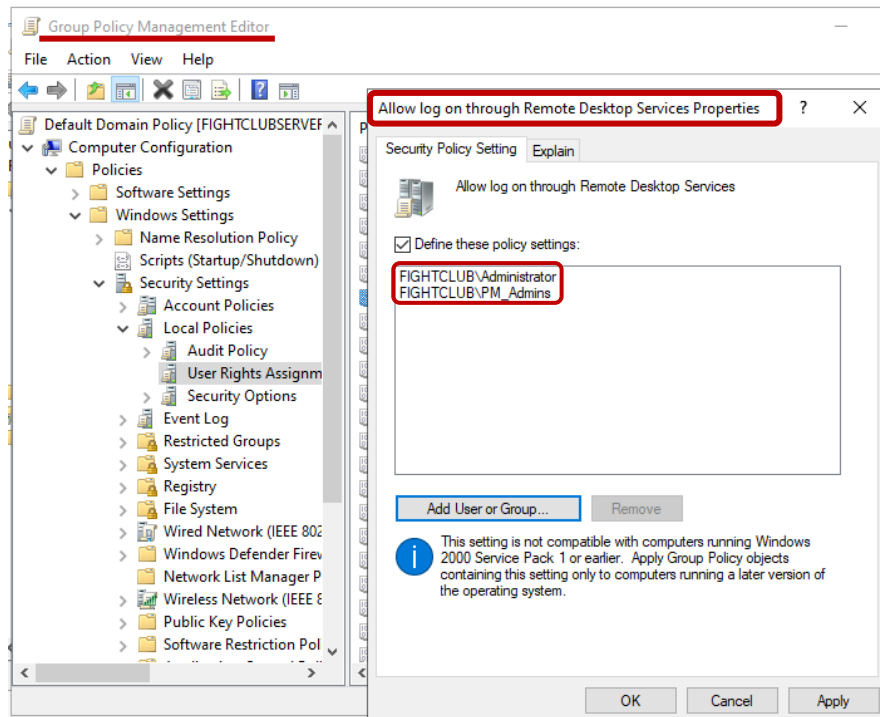
Sul disco locale C:\ del server è stata predisposta una cartella radice denominata progetto, mantenendo i permessi predefiniti per permetterne il solo attraversamento. All'interno, sono state create due sottocartelle soggette a rigide regole di segmentazione degli accessi:

- **Sottocartella C:\progetto\Esplosivi:** L'accesso a questa risorsa è stato reso esclusivo per il gruppo direttivo. Attraverso le proprietà di sicurezza avanzate, l'ereditarietà è stata interrotta, convertendo i permessi in espliciti. Il gruppo generico Users è stato rimosso dalla lista di controllo degli accessi (ACL) ed è stato aggiunto esclusivamente il gruppo PM_Admins con privilegi di **Controllo Completo**.
- **Sottocartella C:\progetto\Piani:** Questa risorsa funge da area di lavoro per gli utenti standard. Seguendo la medesima procedura di interruzione dell'ereditarietà e rimozione del gruppo generico, è stato inserito il gruppo SM_Users con privilegi di **Modifica** (Lettura, Scrittura ed Esecuzione). Questo garantisce la possibilità di consultare e creare file, negando però l'alterazione dei permessi radice o l'eliminazione della cartella stessa.



Accesso Remoto ed Esecuzione (Group Policy Object)

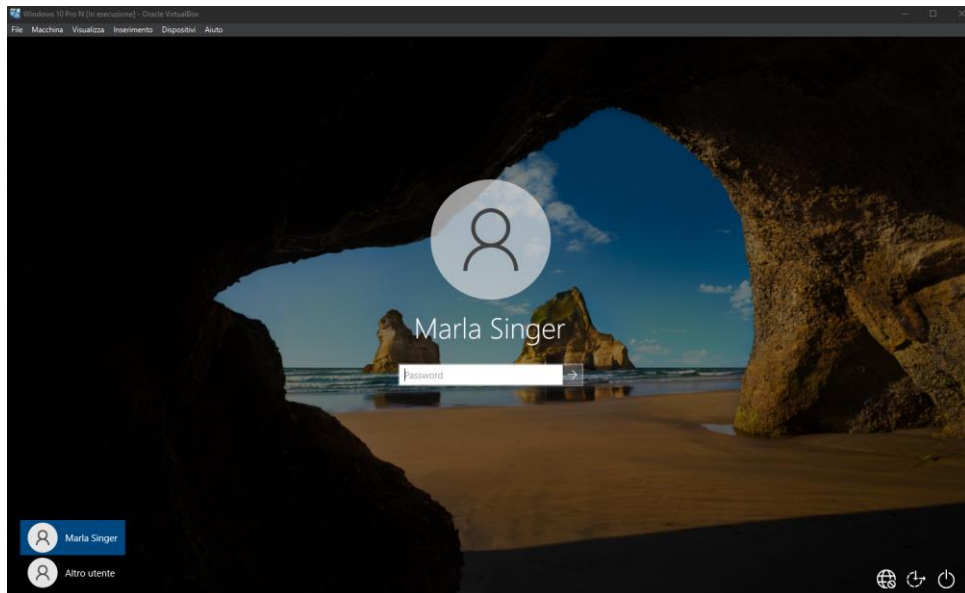
Al fine di proteggere il Domain Controller da accessi non autorizzati, le impostazioni di sistema sono state modificate centralmente. Tramite lo strumento *Group Policy Management*, è stata modificata la *Default Domain Policy*. Nel percorso Computer Configuration > Policies > Windows Settings > Security Settings > Local Policies > User Rights Assignment, la policy "**Allow log on through Remote Desktop Services**" è stata configurata per consentire l'accesso remoto (RDP) unicamente agli amministratori di sistema e al gruppo PM_Admins. Al gruppo SM_Users è stata deliberatamente negata tale facoltà.



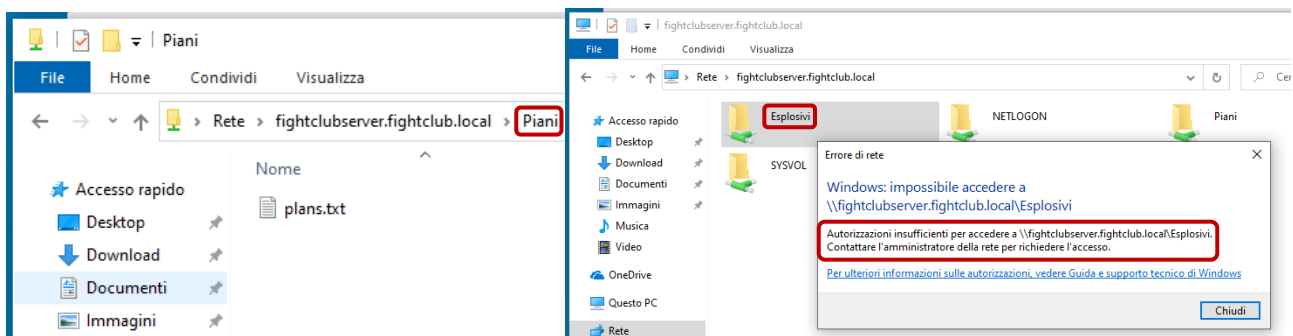
Fasi di Verifica e Testing

La validità dell'architettura implementata è stata testata attivamente utilizzando la macchina Client2.

1. **Test di Logon e Accesso Standard:** È stato effettuato l'accesso sulla macchina client inserendo le credenziali dell'utente di prova Marla Singer (appartenente a SM_Users).



2. **Test di Efficacia NTFS:** Navigando in rete verso le risorse condivise o tramite percorsi mappati, si è verificato l'accesso alla directory aziendale.
 - L'utente ha aperto con successo la cartella Piani e ha dimostrato di poter creare, leggere e salvare un nuovo file di testo, confermando l'applicabilità del permesso di "Modifica".
 - Successivamente, l'utente ha tentato di accedere alla cartella Esplosivi. Il sistema operativo ha correttamente inibito l'apertura, restituendo un prompt di sicurezza con l'avviso *"Non disponi delle autorizzazioni necessarie per accedere alla cartella. Accesso negato"*.
3. **Test Accesso Remoto:** Un tentativo di avviare una sessione di Desktop Remoto (RDP) verso il server tramite account utente standard ha prodotto un blocco di sicurezza, confermando l'efficacia della GPO configurata.



Risoluzione dei Problemi Riscontrati

Durante la fase di implementazione delle restrizioni NTFS, si è verificato un comportamento anomalo: l'utente di test standard riusciva inizialmente ad accedere in lettura a tutte le sottocartelle, violando il principio del privilegio minimo. Un'analisi delle Autorizzazioni Efficaci ha evidenziato che la causa risiedeva nell'ereditarietà dei permessi provenienti dalla radice del disco C:\, la quale assegnava di default permessi in "Lettura ed esecuzione" al gruppo di sistema generico FIGHTCLUB\Users.

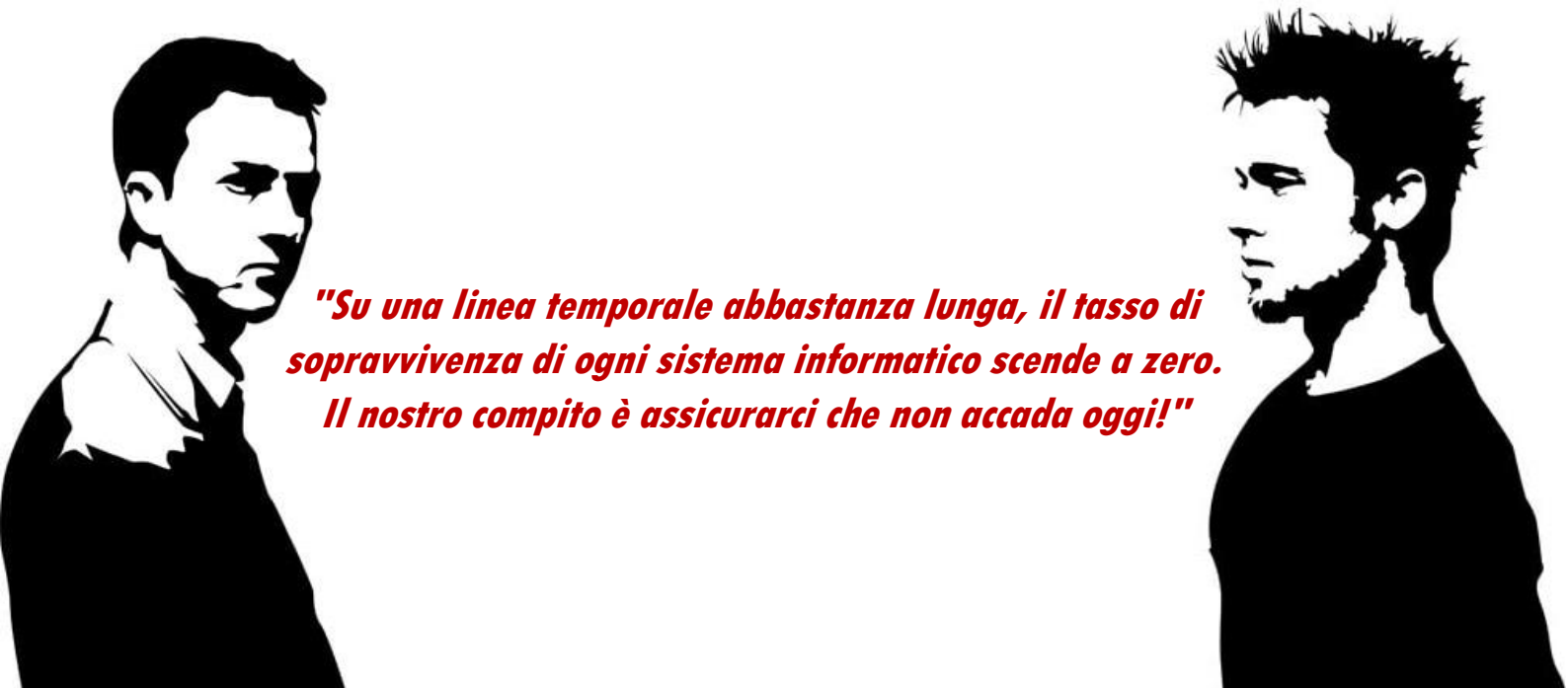
Soluzione adottata: Il problema è stato risolto agendo granularmente sulle singole sottocartelle, disabilitando l'opzione di ereditarietà e convertendo le regole in autorizzazioni esplicite. Sono state quindi selezionate e rimosse manualmente le voci relative a Users, lasciando intatti solo i gruppi amministrativi predefiniti (SYSTEM, Administrators) e inserendo al contempo i nuovi gruppi di sicurezza personalizzati necessari per la segmentazione degli accessi.

Conclusioni e Considerazioni Finali

Il progetto ha dimostrato con successo l'implementazione di un'infrastruttura Active Directory sicura e segmentata, fondata sui principi cardine della sicurezza informatica: il **privilegio minimo** (Principle of Least Privilege) e il **controllo degli accessi basato sui ruoli** (RBAC).

La corretta configurazione delle Unità Organizzative, unita a una gestione granulare delle autorizzazioni NTFS e all'applicazione rigorosa delle Group Policy, ha permesso di isolare efficacemente le risorse critiche (il Domain Controller e le directory riservate) dagli utenti operativi standard (Space_Monkeys), garantendo al contempo la totale libertà d'azione al gruppo direttivo (Project_Mayhem).

I test di verifica condotti lato client e la tempestiva risoluzione delle criticità legate all'ereditarietà dei permessi confermano l'affidabilità dell'ambiente configurato. L'infrastruttura è ora blindata, resiliente contro gli accessi non autorizzati e perfettamente allineata alle direttive di sicurezza centrali: il sistema è pronto, e tutto procede esattamente secondo i piani.



"Su una linea temporale abbastanza lunga, il tasso di sopravvivenza di ogni sistema informatico scende a zero. Il nostro compito è assicurarci che non accada oggi!"